THREAT INTELLIGENCE ADVISORY ? Log4Shell Webshell campaign
==========

Distribution: TLP:AMBER Analyst handoff Confidence: HIGH (IOCs are defanged)
Affected host: log4shell-prod-01 Suspected origin IP: 198.51.100.136

1. EXECUTIVE SUMMARY
An external actor executed a multi-stage post-compromise sequence. Endpoint alerting covered only part of it; several persistence and anti-forensic actions were silent. Map every on-disk finding to the ATT&CK techniques below and flag which are NOT in the SAS alert feed.

2. ATT&CK TECHNIQUE MAPPING (MITRE ATT&CK Enterprise)
  T1190 Exploit Public-Facing Application [initial-access] step 1: Log4Shell RCE (CVE-2021-44228)
  T1505.003 Web Shell [persistence] step 2: JSP webshell planted
  T1059.004 Unix Shell [execution] step 3: reverse shell execution
  T1053.003 Cron [execution] step 4: cron persistence
  T1543.002 Systemd Service [persistence] step 5: systemd persistence
  T1070.006 Timestomp [stealth] step 6: timestomp webshell

3. RELEVANT VULNERABILITIES (source: NVD, US-Gov public domain)
  CVE-2021-44228 CVSS 10.0 (CRITICAL) v3.1 CWE=CWE-20,CWE-400,CWE-502,CWE-917
    Apache Log4j2 2.0-beta9 through 2.15.0 (excluding security releases 2.12.2, 2.12.3, and 2.3.1) JNDI features used in configuration, log messages, and parameters do not protect against attacker controlled LDAP and other JNDI related endpoint
    ref: http://packetstormsecurity.com/files/165225/Apache-Log4j2-2.14.1-Remote-Code-Execution.html

4. INDICATORS OF COMPROMISE (defanged)
  ip 198.51.100.136
  c2 update-log4shell[.]example[.]cn
  pool stratum+tcp[:]//xmr[.]log4shell[.]evil[:]3333
  wallet 4A00000000000000000ce1cc99945b1

Attribution: MITRE ATT&CK(R) (C) The MITRE Corporation, CC BY 4.0. CVE/CVSS from the U.S. National Vulnerability Database (public domain).